

S-A-05 Sanctum Cookie 認証 + JS フロント通知表示

背景・目的

通知ベル UI と通知一覧画面(`/notifications` 静的ページ)はあるが、ベルクリックで一覧画面に遷移するだけで「ちょい見・即既読化」のスナップ動線がない。学習中の受講生は通知の有無を知るためだけに画面遷移が必要で UX が断絶している。また通知を JSON で取得して JS フロントから動的に扱う経路も整っていない。

本チケットは Sanctum Cookie 認証で保護した通知 JSON API(一覧 / 既読化)を新規構築し、TopBar のベルアイコンにフックして「ベルクリックで API を非同期取得 → 通知ポップオーバーで動的表示」する JS フロントエンドを実装する。ポップオーバーには全件 / 未読タブ + 全件既読ボタン + フッターから全通知ページへの導線を備える。受講生学習体験のスナップアウト改善 + 認証付き通知 API の構築 + 実務で頻出する Sanctum SPA Cookie 認証 / `fetch` + CSRF 二段防御 / API レスポンスの整形 を扱う。

ユーザーストーリー

- 受講生(**student**)として、TopBar のベルアイコンをクリックしたら通知一覧画面に遷移せず、その場で最新の通知を確認したい。なぜなら、学習を中断せずに「通知を見るだけ見て学習に戻る」流れを実現したいから。
- 受講生として、ポップオーバーから 1 件クリックして既読化と該当画面遷移を同時にしたい。なぜなら、二段階の操作(まず一覧で開いてから個別行をクリック)が冗長だから。
- 受講生として、ポップオーバーで全件既読ボタンを押すと一気に未読バッジが 0 になる体験を期待する。なぜなら、未読が溜まったときの一括処理を素早く済ませたいから。
- コーチ(**coach**)として、同じ通知ポップオーバーを使う。なぜなら、受講生と同じ通知基盤を共有しており、専用 UI を覚えたくないから。
- 管理者(**admin**)として、本機能(ポップオーバー UI)は対象外。なぜなら、管理者は通知の受信側ではなく配信側で、別画面で運用情報を確認するから。
- 管理者として、通知 JSON API への直叩きアクセスが他人の通知を漏らさない構造を期待する。なぜなら、現状の認証なし API はセキュリティ上の負債で、本番運用前に必ず認証を後付けする必要があるから。
- 管理者として、API への認証は同一オリジンの Cookie ベースで実現しつつ、将来 BE-FE 別オリジン構成に展開できる素地を期待する。なぜなら、実務で BE-FE 別オリジン構成のセキュリティ要件を満たす運用を想定しているから。

要件

通知 JSON API の構築 + Sanctum Cookie 認証(API 保護)

- 通知 JSON API(一覧 / 単一既読化 / 全件既読化)を新規構築し、認証で保護する
- Cookie ベースの認証に CSRF 対策を組み合わせ、なりすまし・偽装リクエストを防ぐ
- API が返す対象は認証ユーザー本人の通知のみとする(本人の通知のみ取得・既読化でき、他者の通知 ID を指定すると拒否される)

JS フロント通知ポップオーバー

- TopBar のベルクリックで通知ポップオーバーを開閉する(フル画面へ遷移するボタンあり)
- ポップオーバー上部でタブを切り替えられる(未読タブには未読件数のバッジが付く)
- 通知行を表示する(未読の目印 / タイトル / プレビュー / 経過時間、未読行は背景を強調)
- 通知が 1 件もないときは空状態を表示する
- 通知行をクリックすると、その通知を既読化して対応する画面へ遷移する
- 全件既読ボタンで未読をまとめて既読化できる
- フッターのリンクから全通知のフルページへ遷移する

TopBar 通知ベル + 未読件数バッジ

未読件数を集計してバッジの初期値を供給する仕組みは既存。受講生はこれを構築せず、ベルクリックのポップオーバー表示とバッジの動的増減(JS)を実装する。

- 未読件数のバッジを常時表示する(未読が 0 件なら非表示、件数が多い場合は適切に表示する)
- ページを開いた時点の初期値はサーバ側で算出した未読件数を表示する
- 通知行のクリックや全件既読の操作に応じて、バッジ・タブの件数を動的に増減させる

アクセス制御(機能群共通)

- 受講生 / コーチには通知ポップオーバーを表示する
- 管理者は対象外
- 認証ユーザー本人の通知のみ API で返り、他者の通知 ID を直接指定するとアクセスできない

スコープ外

- 管理者(admin)向けの通知ポップオーバー — 管理者は通知の受信側ではないため対象外
- Pusher / Broadcasting によるリアルタイム push 受信 — 本チケットは「ベルクリックで fetch」の同期動作のみ
- 通知のフィルタ / 検索 / ポップオーバー内ページネーション — 最新分のみ表示、深掘りは </notifications> フルページに委譲

- 通知の削除 / アーカイブ動線 — 既読化のみ
- 通知種別ごとの細かな UI 出し分け(チャット = チャットアイコン、面談 = カレンダーアイコン等)
- API レスポンスのキャッシュ / 楽観 UI 更新
- BE-FE 別オリジン構成の本格構築 — 実装は同一オリジンで行い、stateful ドメイン設定で別オリジン展開の素地のみ確保する
- Sanctum API トークン認証(PAT)— SPA Cookie 認証のみ
- 通知 JSON API を Web 画面側の経路へ統合すること — API 系統のまま維持する
- バッジ / ポップオーバーの WebSocket / Polling 受信
- フローティング AI 相談ウィジェットとの UI 統合 — 別機能の領域

インターフェース

HTTP	パス	認可
GET	<code>/sanctum/csrf-cookie</code>	認証不要
GET	<code>/api/v1/notifications</code>	<code>auth:sanctum</code> 必須(認証ユーザー本人の通知のみ)
POST	<code>/api/v1/notifications/{notification}/read</code>	<code>auth:sanctum</code> 必須(本人通知のみ)
POST	<code>/api/v1/notifications/read-all</code>	<code>auth:sanctum</code> 必須(自分宛のみ)

通知 JSON API は API 系統のまま維持し、`/notifications` のフルページ(既存)はそのまま並行して動く。受講生 / コーチにはポップオーバーを表示し、管理者は対象外。

画面: ポップオーバーの

HTML(`resources/views/notifications/_partials/notification-popover.blade.php`)とベルアイコンを含む

TopBar(`resources/views/layouts/_partials/topbar.blade.php`)は提供済み(本チケットでの画面変更は不要)。ポップオーバーを動かす JS は提供されておらず、本チケットの実装対象。

初期データ

- 既存の通知基盤をそのまま使う(初期データの新規追加はしない)
- 固定の受講生・コーチに、既読 / 未読を混在させた通知が入っている状態にする(ポップオーバーの表示・既読化・バッジ増減を確認)

メタ情報

項目	値
チケット ID	S-A-05
Feature 連番	notification-03
Feature	notification
種別	Story
サブカテゴリ	既存機能の拡張
難易度	Advance
依存チケット	S-B-04 / S-B-08